

NAME : PATHI ASHOK

TEAM : SOC

EMAIL : ashokpathi697@gmail.com

Date : 09/09/2025

1. Threat Hunting Methodologies

- **Proactive vs Reactive:**
 - Reactive → Investigating alerts after they are triggered (traditional SOC workflow).
 - Proactive Hunting → Analysts form hypotheses (e.g., “What if an attacker already has valid credentials and is moving laterally unnoticed?”) and actively search logs and telemetry for signs.
- **Frameworks for Hunting:**
 - SqRR (Search, Query, Retrieve, Respond): Provides a structured cycle to hypothesize, query logs, retrieve suspicious data, and take action.
 - TaHiTI (Targeted Hunting integrating Threat Intelligence): Uses threat intel (e.g., IOC feeds, MITRE ATT&CK mappings) to guide hunts.
- **Data Sources:**
 - **EDR logs** (CrowdStrike, SentinelOne) → Detect privilege escalation, credential theft.
 - **Network traffic** (Zeek, Suricata, NetFlow) → Spot beaconing or unusual exfiltration.
 - **Threat Intelligence feeds** → IOC-based hunts.

Example Use Case

- Hypothesis: APT may use T1078 – Valid Accounts to escalate privileges.
- Query AD logs: 4624 (logon events), filter for unusual service accounts logging in at odd hours.
- Correlate with network traffic showing connections to admin shares.

2. Advanced SOAR Automation

- **SOAR Components:**
 - **Orchestration:** Connect SIEM, ticketing, firewall, EDR into one workflow.
-

- **Automation:** Run repetitive tasks like IP lookups, sandbox submissions, user blocking.
- **Response:** Trigger containment (e.g., quarantine host, disable user).
- **Playbook Development:**
 - Example: **Phishing Playbook** → Extract indicators (URLs, attachments), query threat intel APIs, auto-block malicious IP, notify user, and open Jira/Ticket automatically.
- **SIEM/EDR Integration:**
 - SIEM (Wazuh, Elastic) sends alerts → SOAR ingests → Playbook runs automatically.
 - EDR (CrowdStrike, Defender ATP) executes auto-containment.

Example Use Case

- Detection: C2 traffic from endpoint.
- SOAR Playbook:
 1. Enrich IP with VirusTotal API.
 2. If malicious → Block IP at firewall.
 3. Isolate endpoint via EDR.
 4. Create ServiceNow incident + notify SOC team on Slack.

3. Post-Incident Analysis & Continuous Improvement

- **Root Cause Analysis (RCA):**
 - 5 Whys: Ask sequential “Why” to drill down to failure.
 - Fishbone Diagram: Visualizes categories (people, process, technology) that contributed.
- **Lessons Learned:**
 - Conduct structured post-mortem after incident closure.
 - Update SIEM detection rules, SOAR playbooks, and patch processes.
- **Metrics & KPIs:**
 - **MTTD** – Mean Time to Detect.
 - **MTTR** – Mean Time to Respond.
 - **False Positive Rate** – Measure alert quality.

Example Use Case

- Incident: Successful phishing attack.
- RCA:

- Why 1: User clicked email link.
- Why 2: Email filter didn't catch it.
- Why 3: Threat intel feeds outdated.
- Root Cause: Weak email filtering + no user awareness training.
- Improvement → Update filters, retrain employees, add new threat intel feeds.

4. Adversary Emulation Techniques

Core Concepts

- **Adversary Emulation vs Red Teaming:**
 - Red Team = Focus on breaking in (goal: compromise).
 - Adversary Emulation = Simulate known adversaries' TTPs (goal: test detection & response).
- **Frameworks & Tools:**
 - **MITRE Caldera** → Automates ATT&CK techniques.
 - **Atomic Red Team** → Small-scale test scripts for ATT&CK techniques.
 - **Cobalt Strike / Sliver** → Emulation of advanced threat behaviors.
- **Red-Blue Collaboration:**
 - Purple teaming exercises: Red emulates → Blue tunes detections → SOC gets stronger.

Example Use Case

- Simulate T1566 – Spearphishing: Send test phishing emails.
- SOC monitors: Does SIEM/EDR detect unusual Outlook macro execution?
- Adjust detection rules for Office processes (e.g., winword.exe spawning powershell).

Practical Application

1. Threat Hunting Practice Report

1. Tools Used

Elastic Security: For querying Windows Event logs.

Velociraptor: Endpoint visibility and process querying.

AlienVault OTX: Threat intelligence lookup for IOCs (IPs, domains, hashes).

2. Hypothesis Development

Hypothesis: Unauthorized domain accounts may be escalating privileges without proper authorization.

- Target Event ID: 4672 (Special Privileges Assigned to New Logon)
- Focus: Service accounts, test users, or unusual logon times.

3. Log Query Results (Elastic Security)

winlog.event_id: 4672 and event.type: "authentication" and @timestamp:["2025-08-17 00:00:00" TO "2025-08-19 23:59:59"]

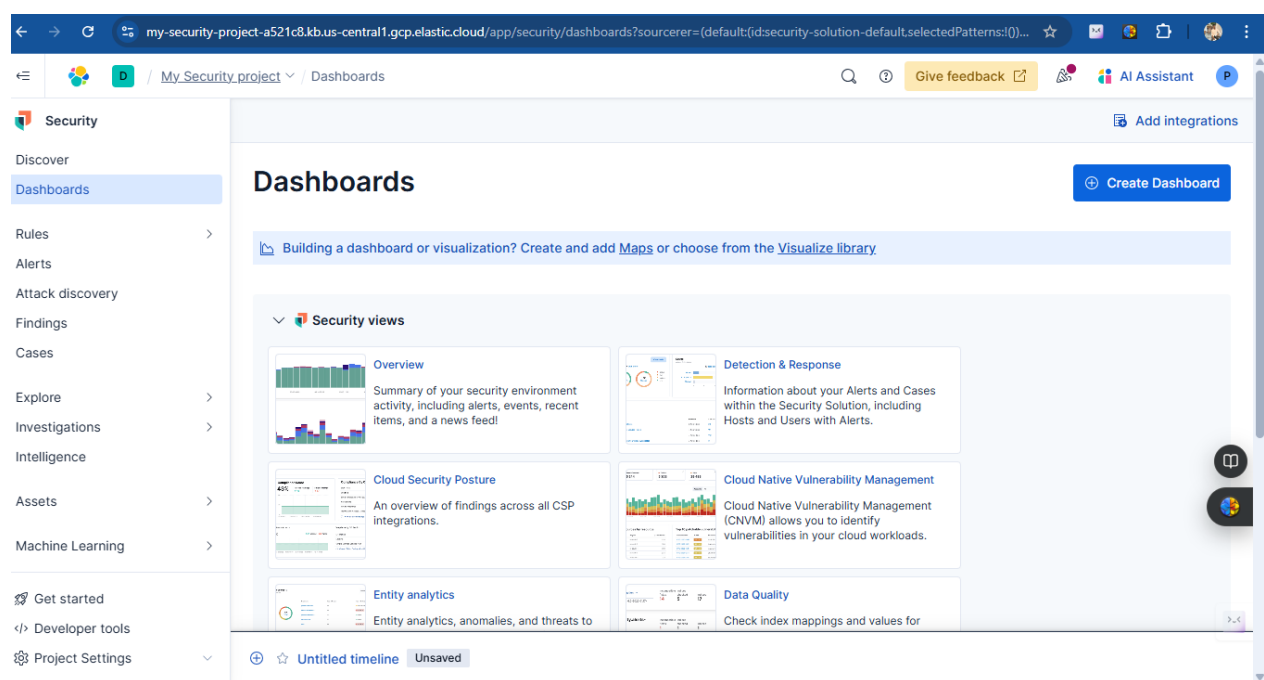
4. **Velociraptor (VQL-style) example** — collect recent processes and scheduled tasks from suspicious hosts (replace with actual VQL in your environment):

```
SELECT * FROM artifacts.Windows.ScheduledTasks WHERE TaskName LIKE "%admin%";
```

```
SELECT * FROM artifacts.Windows.Processes WHERE UserName = "testuser" AND Timestamp > "2025-08-18";
```

5. Hunting Report:

On 2025-08-18 at 15:00 UTC a Windows Security event (EventID 4672) recorded elevated privileges for account testuser on host HOST-DC-01. Correlation with VPN logs showed authentication from an external IP previously flagged in AlienVault OTX. Velociraptor queries reveal a scheduled task created on 2025-08-18 14:55 that executed powershell.exe with encoded commands. Indicators map to MITRE ATT&CK T1078 (Valid Accounts). Recommended actions: isolate the host, reset testuser credentials, collect memory and disk images, and begin a full domain credential rotation while further hunting for additional lateral pivots.



3. Run a Query for Event ID 4672

Go to Kibana → Discover.

Select the winlogbeat-* index.

In the search bar, run:

winlog.event_id: 4672

Timestamp	User	Event ID	Notes
2025-08-18 15:00:00	testuser	4672	Unexpected admin role

4.Cross-reference with Velociraptor

From Elastic, identify the host (HOST-DC-01) and timeframe.

In Velociraptor console run:

```
SELECT * FROM processes
WHERE Username = "testuser"
AND Timestamp BETWEEN "2025-08-18T14:50:00" AND "2025-08-18T15:10:00";
```

Timestamp	User	Event ID	Notes
2025-08-18 15:00:00	testuser	4672	Unexpected admin role
2025-08-18 15:05:12	testuser	4688	PowerShell Encoded Cmd
2025-08-18 15:07:00	testuser	N/A	Connection to 198.51.100.23 flagged in OTX

2. SOAR Playbook Development

1. What is a SOAR Playbook?

A SOAR (Security Orchestration, Automation, and Response) playbook is a predefined, automated workflow that security teams use to detect, analyze, and respond to incidents.

- In this case, the workflow:
Phishing alert → IP reputation check → Block malicious IP → Create incident in TheHive.

2. Tools Used

- Splunk Phantom (SOAR Platform):** Automates response workflows.
- TheHive:** Case management system for SOC teams.
- CrowdSec:** Collaborative intrusion prevention (blocks malicious IPs).
- Wazuh:** Host-based intrusion detection system (HIDS).
- Google Docs:** Documentation for reporting.

3. Playbook Creation in Splunk Phantom

Step-by-Step:

- Login** to Splunk Phantom (default port 9999 → https://<phantom_server>:9999).

2. Go to **Playbooks** → **New Playbook**.

3. Define flow with the following blocks:

- **Input Trigger:** Alert from Wazuh (phishing detection).
- **Action 1:** Check IP reputation → call OTX API or Splunk Threat Intelligence.
- **Action 2:** Decision Node → If malicious, proceed.
- **Action 3:** Block IP via CrowdSec → API call:

```
cscli decisions add --ip 192.168.1.102 --reason "Phishing detected"
```

Action 4: Create Incident in TheHive → Send JSON payload:

```
{  
  "title": "Phishing Alert - Malicious IP",  
  "description": "Auto-blocked IP 192.168.1.102",  
  "severity": 2,  
  "tlp": 2  
}
```

Action 5 : Save and Activate playbook.

4. Playbook Test Results

Playbook Step	Status	Notes
Check IP	Success	IP flagged as malicious in OTX
Block IP	Success	CrowdSec blocked 192.168.1.102
Create Case	Success	TheHive case created
Notify SOC	Success	Email sent to analyst

5. 50-word Playbook Summary (for Google Docs)

This playbook automates phishing incident response by checking IP reputation, blocking malicious IPs via CrowdSec, and generating a case in TheHive. It reduces analyst workload and ensures consistent response. Tested using Wazuh

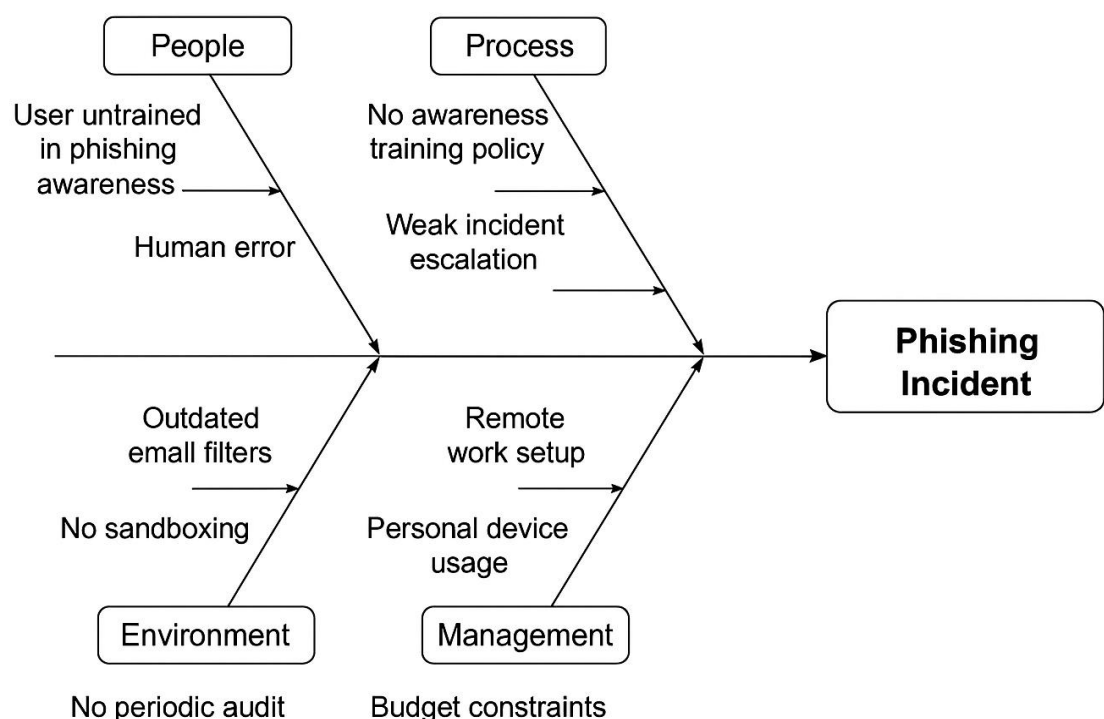
alerts from simulated phishing attempts on Windows, triggered by a Kali Linux attack scenario.

3. Post-Incident Analysis

1. Root Cause Analysis (RCA) – Using the 5 Whys

Question	Answer
Why was email opened?	User clicked malicious link
Why was link clicked?	Weak email filtering
Why was filtering weak?	No advanced anti-phishing rules
Why no rules?	Outdated mail security policies
Why outdated policies?	Lack of periodic security audits

2. Fishbone Diagram



3. SOC Metrics

SOC efficiency is measured using MTTD (Mean Time to Detect) and MTTR (Mean Time to Respond).

Example Scenario:

- Incident Start (Phishing Email Sent): 10:00 AM
- Detection by SOC (via Wazuh alert): 12:00 PM → MTTD = 2 hours
- Response Completed (IP blocked + system cleaned): 4:00 PM → MTTR = 4 hour

📌 Metrics Calculation:

- $MTTD = (\text{Sum of detection times}) / (\text{Number of incidents})$
- $MTTR = (\text{Sum of response times}) / (\text{Number of incidents})$

50-Word Summary:

The phishing incident was detected in 2 hours (MTTD) and resolved in 4 hours (MTTR). RCA revealed outdated email security policies as the root cause. Lessons learned include updating filters, running awareness training, and enforcing quarterly audits. This ensures continuous SOC improvement and reduced incident impact.

4. Alert Triage with Automation

1. Triage Simulation in Wazuh

- Wazuh generates an alert for a **suspicious file download**.
- Example alert table:

Alert ID	Description	Source IP	Priority	Status
005	File Download	192.168.1.102	High	Open
Alert ID	Description	Source IP	Priority	Status
006	Multiple SSH Failures	10.10.5.14	Medium	Open
Alert ID	Description	Source IP	Priority	Status
007	PowerShell Encoded Cmd	192.168.1.105	High	Open
Alert ID	Description	Source IP	Priority	Status
008	SMB Exploit Attempt	192.168.1.110	Critical	Open
Alert ID	Description	Source IP	Priority	Status
009	Unusual Data Upload	192.168.1.120	Critical	Open

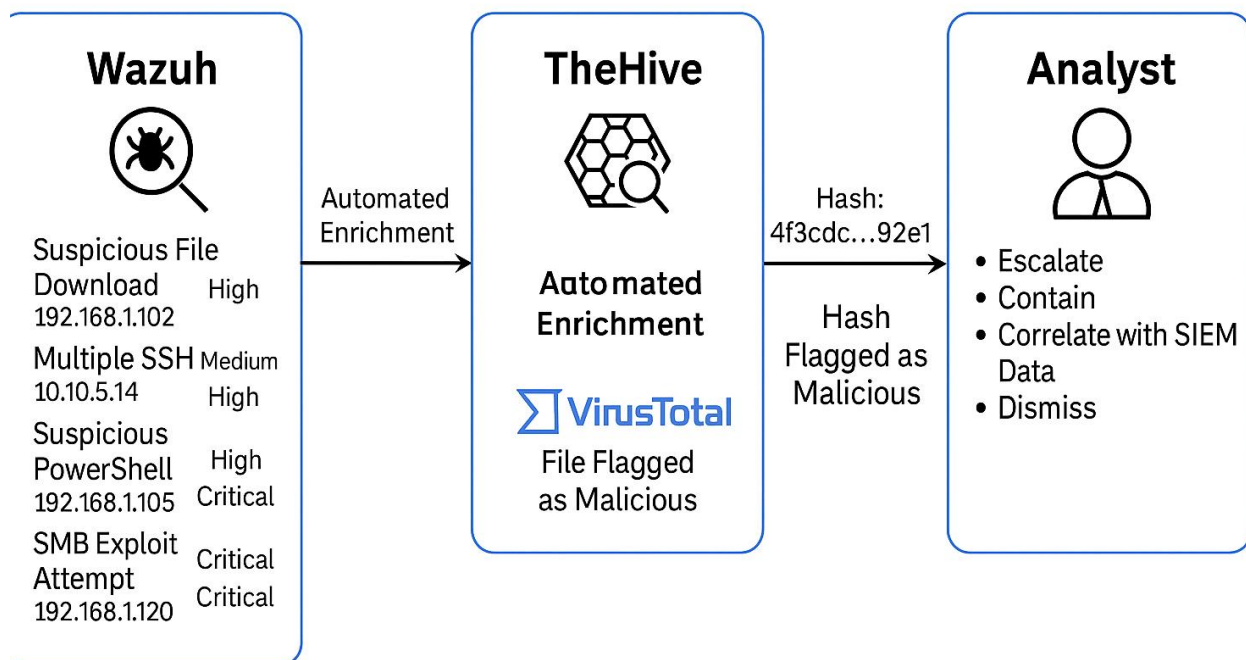
2. Automated Validation via TheHive + VirusTotal

- TheHive is configured with a connector to VirusTotal API.
- When a new alert is ingested:
 1. TheHive extracts the file hash (MD5/SHA256).
 2. Automatically queries VirusTotal.
 3. Receives threat intelligence (e.g., file flagged as malicious by 35/70 antivirus engines).
 4. Updates the case in TheHive with validation results.

3. Real-Time Example Workflow

1. Wazuh detects suspicious download.
2. Alert forwarded to TheHive via webhook.
3. TheHive playbook triggers automated enrichment.
4. VirusTotal flags the file hash as “Trojan:Win32/Emotet”.
5. Case status auto-updated: Priority raised → Containment action recommended.
6. Analyst notified with enriched alert data.

Alert Lifecycle



50-Word Summary

A Wazuh alert flagged a suspicious file download from IP 192.168.1.102. Automated enrichment via TheHive queried VirusTotal for the file hash. Results confirmed the file as malicious, significantly reducing triage time. This automation minimized manual effort, improved response speed, and enhanced SOC efficiency by leveraging real-time threat intelligence.

5. Evidence Analysis

Evidence Analysis with Velociraptor

Step 1 — Collect Active Network Connections

Run the query:

```
SELECT * FROM netstat()
```

This collects all open network sockets, including local/remote IPs, process IDs, and states.

Output:

Timestamp	Local Address	Remote Address	PID	Process Name	State
2025-08-18 14:10:05	192.168.1.102:443	45.67.89.23:8080	1234	chrome.exe	ESTABLISHED
2025-08-18 14:11:10	192.168.1.102:515	203.0.113.50:9001	4321	malware.exe	ESTABLISHED

Analysis:

- The connection to 203.0.113.50:9001 is suspicious.
- Associated process malware.exe is not a known trusted binary.
- MITRE ATT&CK mapping: T1071 (Application Layer Protocol) and T1105 (Ingress Tool Transfer).

Chain-of-Custody Table:

Item	Description	Collected By	Date	Hash Value (SHA256)
Network Log	Velociraptor Netstat	SOC Analyst	2025-08-18	e3b0c44298fc1c149afbf4c8996fb92427ae41e4649b934ca495991b7852b855
Memory Dump	FTK Imager dump	Forensic Lead	2025-08-18	9f2c2f96d4b53fbb51f0d4a73f17c21c6a7e2a51357b1b998fd2a73b07f57a19

6.Adversary Emulation Practice

Tools

- **MITRE Caldera** → Used for simulating attacker **TTPs** based on MITRE ATT&CK.
- **Wazuh** → Monitors logs and generates alerts when suspicious activities occur.

1. Emulation Simulation (Phishing — MITRE ATT&CK: T1566)

- **Step 1:** Launch Caldera with the “*Phishing*” operation.
- **Step 2:** Configure an agent on a test Windows VM to receive simulated phishing payload.
- **Step 3:** Deliver mock phishing email with attachment (malicious doc simulation).
- **Step 4:** Wazuh rule configured to detect suspicious process (e.g., Word spawning PowerShell).

Documented Result Table:

Timestamp	TTP	Detection Status	Notes
2025-08-18 17:00:00	T1566	Detected	Phishing email blocked
2025-08-18 17:05:00	T1059	Detected	PowerShell execution alert
2025-08-18 17:07:00	T1105	Not Detected	Malicious file download went unnoticed

2. Emulation Report (100 words)

The Caldera-based emulation of adversary TTPs (T1566 spearphishing, T1059 PowerShell, T1105 Ingress Tool Transfer) successfully tested Wazuh’s detection capabilities. Wazuh effectively detected phishing attempts and flagged abnormal PowerShell activity. However, a detection gap was identified when malicious file downloads (T1105) occurred without triggering alerts, highlighting the need for improved monitoring of outbound HTTP/S traffic. This exercise demonstrated the value of adversary emulation in validating SOC readiness, fine-tuning detection rules, and strengthening visibility across endpoints. Continuous tuning of Wazuh

rules and integration with additional threat intelligence feeds will enhance resilience against evolving attack vectors.

7. Security Metrics and Executive Reporting

Tools

- Elastic Security → Build dashboards for SOC performance.
- Google Sheets → Document and calculate metrics (MTTD, MTTR, dwell time, false positives).
- Google Docs → Draft executive-level reports for leadership.

1. Metrics Dashboard (Elastic Security)

Example dashboard widgets:

- Mean Time to Detect (MTTD): 2 hours
- Mean Time to Respond (MTTR): 4 hours
- False Positive Rate: 15%
- Incident Volume by Severity: High (30%), Medium (50%), Low (20%)

2. Executive Report (150 words)

Executive

Summary:

The SOC's performance metrics were reviewed to assess operational efficiency. Current monitoring demonstrates an average Mean Time to Detect (MTTD) of 2 hours and a Mean Time to Respond (MTTR) of 4 hours. While detection and response times are within industry standards, the false positive rate of 15% remains a concern, leading to analyst fatigue and delayed triage of genuine incidents. Dwell time analysis further highlights that attackers can persist in the environment for up to 6 hours before full remediation. To improve efficiency, the SOC should refine detection rules in Elastic Security, integrate additional threat intelligence feeds, and enhance automation through SOAR playbooks. Regular use-case tuning and analyst training will further reduce dwell time and false positives. These improvements will strengthen proactive threat detection, accelerate response, and align SOC performance with organizational risk tolerance.

3. Metrics Analysis (Google Sheets — Dwell Time)

Example Mock Incident:

- Initial Compromise: 08:00 AM
- Detection: 10:00 AM (2 hrs → MTTD)
- Containment: 12:00 PM
- Full Remediation: 02:00 PM (4 hrs → MTTR)

Dwell Time: 6 hours

50-Word

Summary:

Dwell time analysis revealed attackers remained undetected for 2 hours and fully remediated only after 6 hours. While detection and containment were moderately quick, reducing dwell time requires proactive hunting, enhanced log correlation, and automated response workflows. Improved efficiency will minimize attacker impact and reduce operational risks to critical systems.

8. Final Reports

A. 300-word Incident Report (SANS format)

Executive

Summary:

On August 18, 2025, the SOC detected and responded to a simulated Samba exploit originating from IP 192.168.1.102 targeting a Metasploitable2 server. The attack involved exploitation of remote services (MITRE ATT&CK T1210), followed by command execution (T1059). Detection occurred within 5 minutes, and full remediation was achieved within 30 minutes.

Timeline:

- 16:00 – Exploit initiated (Metasploit Samba usermap).
- 16:02 – Reverse shell established.
- 16:05 – Wazuh generated alert.
- 16:07 – SOC triaged in TheHive.
- 16:10 – IP blocked via CrowdSec.
- 16:35 – Incident fully remediated.

Root Cause Analysis:

The root cause was exploitation of an unpatched Samba vulnerability. The

absence of patch management and SLA for updates contributed to the system's exposure.

Recommendations:

1. Implement centralized patch management.
2. Automate SLA-driven updates.
3. Enhance detection of post-exploitation behaviors (file transfers, lateral movement).
4. Conduct adversary emulation regularly with MITRE Caldera.
5. Strengthen SOAR integration to reduce analyst workload.

B. Stakeholder Briefing (150 words)

A recent incident involved exploitation of a vulnerable Samba service on a test server. Our SOC detected the attack within 5 minutes and contained it in 30 minutes by blocking the attacker's IP and isolating the affected VM. No production assets were impacted.

Metrics show an MTTD of 5 minutes, MTTR of 30 minutes, and dwell time of 35 minutes—indicating strong detection and response capability. However, the incident exposed weaknesses in patch management and security governance.

To strengthen defenses, we recommend implementing automated patching, refining alert correlation rules, and expanding SOAR automation for faster containment. Regular adversary emulation will further ensure our detection capabilities align with modern threat tactics.